

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
March 2026	Data Protection	DP001.P	Livia Li	Updated the testing references
April 2025	All	All	Livia Li	Updated links and applicable testing
April 2024	Planning	Self-Service Report and Fraud Template	Jessica Lin	Added Self-Service Report (WWBCIT), updated links and proper nouns
April 2023	Data Protection	DP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	6
PLANNING: Self-Service Report	7
PLANNING: Fraud Template.....	8
CONTROL ASSESSMENT QUESTIONS	9
Key Control Question: 1. Compensation.....	9
Primary Test: Compensation Process Design (CM001.P).....	10
Primary Test: Acquired Employees - Post Integration (CM002.P)	11
Key Control Question: 2. Data Protection.....	12
Primary Test: Data Protection (DP001.P).....	13
Key Control Question: 3. Business Continuity Planning.....	15
Secondary Test: Business Continuity Planning (BC001.S)	16

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PROCESS AND OBJECTIVE

The Global Compensation process is a sub-process within the human resources (HR) process. It encompasses the design of processes and tools used to determine and administer compensation and recognition programs.

The process is executed using global Compensation tool(s) where all amounts are monitored, authorized and approved within the tool(s).

Global Incentives and Commissions design and execution are addressed in a separate auditable process (58-00-00), not owned by HR. The Global Incentives and Commissions process owner reports to the Vice President of Global Sales Incentives, which is part of Enterprise Services within the Transformation and Operations Organization.

Execution of compensation and recognition payments are handled by other auditable processes. For employees, the process is Payroll (18-20-00), which is a sub process of the Disbursements process (18-00-00).

Process Objective:

IBM's compensation and recognition programs are designed to attract, retain and motivate high-performing employees and executives. The principles of our compensation strategy are to pay for performance, pay competitively and differentiate strongly.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PLANNING: Audit Program Risk Alignment

Global Compensation

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Data Privacy	High	Data Protection	DP001.P
Compensation Decisions	Medium	Compensation	CM001.P
Approvals	Medium	Compensation	CM001.P
Acquired Employees (Acquisitions)	Medium	Compensation	CM002.P
Reconciliations	Low	Compensation	CM001.P

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Universe of compensation transactions.	Within program guidance and approved.	Increase may be outside of the established ranges or paid outside of the compensation period without proper reviews and or approvals.	

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PLANNING: Reference Material

IBM Corporate Directives - these can change over time

Corporate Policies

- 117: Workforce Diversity <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-117>
- 130: IBM Data Privacy Policy <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

Corporate Instructions

Chief Information Officer

- ITS101: Information Technology Security <https://w3.ibm.com/ibm/corporate-documents/its/its101>

Finance

- FIN 101: Control of Disbursements <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 151: Application Systems Control and Auditability (ASCA) <https://w3.ibm.com/ibm/corporate-documents/fin/fin-151>

Global Procurement

- PROC167: Supplier sourced goods and services <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>

Legal

- LEG 116: Classification and Control of IBM Information <https://w3.ibm.com/ibm/corporate-documents/leg/leg-116>
- LEG 117: Internet Privacy - Personal Information Collected On-Line <https://w3.ibm.com/ibm/corporate-documents/leg/leg-117>

Enterprise Transformation (ET)

- ET 127: Business Continuity Management <https://w3.ibm.com/ibm/corporate-documents/et/et-127>
- Human Resources

- HR 113: Protection of Employee Information <https://w3.ibm.com/ibm/corporate-documents/hr/hr-113>

- Data Privacy/Protection, Regulations, and Compliance: <https://w3.ibm.com/w3publisher/dprc>

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
• Management Self-Assessment of Controls (MSAC) • Risk Evaluations (RE's) • Proactive Business Control Reviews • (No key controls)	WorldWide Business Controls Integrated Toolset (WWBCIT) is being replaced by Finance Business Controls OpenPages in 1Q 2025. For the data prior to 1Q 2025: Option 1: Login to WWBCIT. In the left side menu, select "Manage self assessment," "Risk evaluations," or "Proactive process review," and then select the applicable criteria to get the results. Option 2: Login to WWBCIT Cognos reports • Select "BCIT406 – Management Self Assessment Trending Report" or • Select "BCIT211 – Risk Evaluation Report" or • Select "BCITLL – Lessons Learned Detail Report," and then select the applicable criteria to get the results. For the data starting from 1Q 2025: Login to OpenPages, change the profile to "FBC General User". • Select the applicable process from the primary menu on the top left for all process related materials. • On the home page, select the report and export it with applicable criteria. Note: The reported (global) process: Global Compensation

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

- Given the systems used and the controls established, there are no known fraud risks at this time.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Compensation

Objective:

Compensation process design includes developing and implementing programs and tools to administer employee (including executive) compensation according to the design of the specific program.

Risk/Exposure:

Failure to properly design, administer, and monitor compensation and recognition programs could result in excess expenditures and disputes.

Control Assessment Topics:

- Compensation process design including tools, communication, and reviews and approvals.
- Data privacy, including how personal information (PI) and sensitive personal information (SPI) is handled among or between IBM organizations and third-party vendors involved.

Other Tests:

Be mindful of the following:

- Protection of sensitive personal information (SPI) is critically important and is required by law in many places around the world.
 - Specified by Corporate Privacy Office as part of IBM's Global Privacy Assessment (GPA) program, assessed via the Global Privacy Assessment Tool (GPAT).
- Review the following, noting how each is periodically validated and reported:
 - Separation of duties: assess roles, tasks, and access to applications to understand what employees can do with the roles and tasks assigned, in conjunction with the access to applications and data they have been granted.
 - Access to data and applications: review the three elements of access management:
 1. Granting access
 2. Periodically reviewing access
 3. Revoking access
- Employees performing HR work may be IBM regular employees and may be contractors. Where work is performed by contractors, review the following:
 - Contract management with the contractor's company
 - Confidentiality disclosure agreements
 - Separation of duties
 - Access to data and applications
 - Contractor selection, engagement, and disengagement
 - Records management

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Compensation

Primary Test: Compensation Process Design (CM001.P)

Objective:

Compensation process design includes developing and implementing programs and tools to administer employee (including executive) compensation according to the design of the specific program.

Approach:

From the scheduled cycle(s) processed through the Compensation tool(s) review:

- Control reports, error reports, exception reports and reconciliations used to ensure that all changes are documented, valid, approved, processed in a timely manner, and have appropriate management visibility.
- For tools, determine if controls are effective to prevent and detect improper or incomplete transmissions of data, and ensure that all transmissions are controlled to occur on a scheduled basis (e.g., Comp to HR system). Verify that reconciliations are completed timely.
- Review the design of the process:
 - How are process requirements communicated to line management?
 - How are decisions reviewed, and by whom? For example, what is HR's role in the review process, in addition to line management?

From a universe of compensation transactions, examine a judgmental sample. Evaluate whether compensation and recognition decisions were made according to the guidance applicable to that program and were approved by management according to the approvals process applicable to that program before the decisions were executed.

- Choose some samples involving retention payments. Check to see whether repayment agreements were in place. Were conditions met as required? If not, what was the process for capturing repayment?
- Test out of cycle salary increases.
- Review samples of award payments to be sure these were within program guidelines and were approved as required.
- Select samples with multiple payments to individuals, such as more than one salary increase or multiple awards, etc.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Compensation

Primary Test: Acquired Employees - Post Integration (CM002.P)

Objective:

To Test:

- If acquired employees have compensation policies different to what is IBM standard:
 - Was there an agreement to move acquired employees to IBM standard compensation program design and execution? If so, did this change occur when required (or was an extension or exception approved)?
 - Were the compensation transactions for the acquired employees administered in accordance with the (non-standard) policy which applied to them?

Approach:

For all cases, ask for information in the IDR on any acquisition where compensation ownership was accepted by HR during the audit period in scope:

- Request information on the timeline and integration status of the acquisition.
- Ask for a listing of the acquired employees including IBM serial numbers.

Compensation - In your sample, be sure to ask for and review any compensation policy different to what is standard IBM process.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Protection

Objective:

This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process.

Risk/Exposure:

Failure to protect PI and SPI could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Protection

Primary Test: Data Protection (DP001.P)

Objective:

This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process.

Approach:

Consider ways that PI and SPI could be compromised. Review common tests for anyone involved in performing process steps. This includes IBM employees, contractors working for IBM departments, and vendor firms (their employees).

- Access to data and applications (including granting, periodic revalidating, and revoking).
- Separation of duties.
- File transfers among IBM and vendors, including encryption and classification as IBM Confidential.
- Spreadsheet protection.

Review contracts with vendors or contractors. How is data privacy assured? Are periodic reviews, such as service organization controls (SOC) report, required by IBM? How does IBM monitor vendor protection of data? Are IBM's information technology standards in place, monitored, and enforced?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Protection

Primary Test: Data Protection (DP001.P)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education.

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education.

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Business Continuity Planning

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Risk/Exposure:

Any material disruption of business operations due to natural or man-made disasters can lead to significant financial loss not only IBM but potentially also for IBM's customers and vendors. Many business processes have been centralized, and often operations are conducted in locations which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations in those centralized operations.

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

Note: Business continuity risks become increasingly important in the environment where there are centers of excellence and multiple countries are supported by one center. This should therefore be an important test and considered primary in that environment. IT testing for disaster recovery is handled by the IT audit teams.

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Approach:

A guideline has been put in place for process owners providing guidance on business continuity planning (BCP). It should be noted by the audit team that this is a guideline rather than a specific instruction. However, it will act as a guide for you to understand whether key risks have adequately been considered for BCP and enable you to make an informed judgement regarding the risk mitigation in place. Different processes will have their own unique risk profiles regarding the probability and impact of an interruption to business operations. For example, the probability and impact of a business interruption for a process which has been centralized for multiple countries in a location with less-developed infrastructure is likely greater than that of a process supporting only a single country in location with robust infrastructure. As such, auditor judgment will be required to determine how important BCP is for a particular process, as well as to determine the reasonableness of any plans that have been designed by the process owners.

In the initial data request information ask for the process owner to confirm what plans have been implemented to ensure business continuity in the event of a natural or man-made disaster. Review that non-I/T process elements have been adequately considered in the BCP.

The following list of questions has been designed based on the BPBC127 Guideline for Business Process - Area Business Continuity Planning.

- Has management assessed the risk to business continuity (BC) and identified the key business processes and activities that require formal business continuity planning based on impact to the business.
 - a. Identification and prioritization of business processes' activities in addition to prioritization done through by the Enterprise Process Owner (level 3 plans).
 - b. Understanding and documentation of the potential impact (financial, operational and reputation) to IBM from business disruptions from uncontrolled, non-specific events.
 - c. Identification of the legal and regulatory requirements for the institution's business functions and processes.
 - d. Review and approval from senior management.
- For critical business areas and processes, has the maximum acceptable outage (MAO) been established and considered in the BC plan?
 - a. Estimation of maximum allowable outage (MAO), based on the "acceptable level" of losses, associated with the institution's business functions and processes.
 - b. Estimation of recovery time objectives (RTOs), recovery point objectives (RPOs), and Maximum Tolerable Downtime (MTD) of applications and supporting technology required for business operations.
 - c. If applicable, recommended critical path recovery order.
 - d. Reconciled with agreed IT recovery priorities (Business Criticality Values, RTO/MTD).

GLOBAL COMPENSATION AUDIT PROGRAM #40-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Business Continuity Planning

Secondary Test: Business Continuity Planning (BC001.S)

(Continued)

- For business areas and processes where there is a business continuity risk, has the BC Plan been created, reviewed, and approved by management?
 - a. The organization shall establish documented procedures for responding to a disruptive incident and how it will continue or recover its activities within a predetermined timeframe.
 - b. Top management shall review the organization's Business Continuity Management System (BCMS), at planned intervals, to ensure its continuing suitability, adequacy, and effectiveness.
- Does the Plan document the specific continuity and recovery actions for all four impact scenarios (workforce, workplace, IT, and regional) that will need to take place to mitigate risk to the business if the impact lasts longer than the documented business' maximum acceptable outage?
 - a. Flexible to respond to unanticipated threat scenarios and changing internal conditions.
 - b. Focused on the impact of various threats that could potentially disrupt operations rather than on specific events.
 - c. Effective in minimizing service disruptions and financial loss through the implementation of mitigation strategies.
- Does the BC plan clearly identify dependencies such as site resources, IT, suppliers, process interdependencies, partners, non-IT services and been reviewed and synchronized with the appropriate crisis management team?
 - a. An effective BCP coordinates across its many components, identifies potential process or system dependencies, and mitigates the risks from interdependencies.
- Is there an established, management-endorsed business continuity team to oversee the maintenance, invocation, and execution of the BC plan?
 - a. Defined roles and responsibilities for people and teams having authority throughout an incident.
 - b. Additional teams as necessary to facilitate recovery execution per the chosen strategy.
- Are personnel aware and educated on the plan, strategy, and roles?
 - a. Business continuity training should be an integral part of the Business Continuity Management (BCM).
 - b. Comprehensive training program should be developed for all employees, conducted at least annually, and kept up to date to ensure that everyone understands their current role in the overall recovery process.
 - c. An audit trail should be maintained to document management's training efforts.
- Is there a regularly executed process for validating the Plan through tests including key elements such as people, technology (data, systems, applications, and telecommunications), and locations that house staff and technology to ensure fit for purpose and alignment with current risks?
 - a. Tests should be based on appropriate scenarios that are well planned with clearly defined aims and objectives that promote continual improvement.
 - b. Produce formalized post-exercise reports that contain outcomes, recommendations, and actions to implement improvements and are reviewed with management.
 - c. Tests are conducted at planned intervals and when there are significant changes within the organization or to the environment in which it operates.